Corso di Laurea Triennale in

Informatica per le aziende digitali L-31

Sviluppo di un software mobile-friendly per il calcolo

del fattore di rischio

Sicurezza aziendale: Calcolo e Gestione del Rischio

CANDIDATO:

Russo Vincenzo

MATRICOLA:

0312302103

Anno

Accademico

2025/2026

Indice

Introduzione

Capitolo 1 – Sicurezza informatica e gestione del rischio

- Definizione di rischio informatico
- Minacce principali e vulnerabilità aziendali
- Impatto economico e operativo

Capitolo 2 – Calcolo del fattore di rischio

- Importanza del calcolo del rischio
- Formule e metodologie di analisi
- Applicazione pratica del calcolo del rischio

Conclusioni

Introduzione

Negli ultimi anni la sicurezza informatica è diventata una questione importante per le istituzioni pubbliche, per le imprese e per i cittadini. Oggi la vita è sempre più digitale e per questo creiamo, scambiamo e archiviamo continuamente tante quantità di dati.
Da una parte la tecnologia ha semplificato molte cose e ha portato nuove opportunità. Dall'altra parte la sicurezza informatica ha subito più rischi.
I dati ora sono più esposti a minacce come gli attacchi informatici, il furto di dati sensibili e i programmi dannosi. Io penso che la sicurezza informatica debba essere una priorità per tutti.

La cybersecurity non si ferma solo a difendere i dati personali. La cybersecurity deve anche proteggere la stabilità dei sistemi, far sì che i servizi continuino a funzionare e far rispettare le leggi. Un attacco informatico può provocare danni davvero gravi: basta immaginare un ospedale che non può aprire le cartelle cliniche, una banca il cui sistema è bloccato, o una centrale elettrica che non riesce più a fornire energia. Per questo motivo, i governi e le organizzazioni internazionali hanno introdotto regole e norme precise per proteggere le reti. Le soluzioni digitali limitano i rischi. È fondamentale limitare i rischi legati agli incidenti informatici con le soluzioni digitali per proteggere i dati e garantire la continuità operativa.

Nel mio Project Work voglio approfondire la sicurezza informatica. Per farlo studio le tecniche che servono a valutare il rischio.
Mi concentro soprattutto sul calcolo del fattore di rischio. Poi presento una panoramica delle pratiche più efficaci che il settore usa per proteggere le infrastrutture digitali.

Nel dettaglio, il lavoro comprende:

- Studio delle più importanti minacce informatiche.

- Studio delle metodologie di valutazione del rischio.

- Spiegazione di un modello di calcolo del rischio.

Al giorno d'oggi ogni organizzazione deve occuparsi del rischio informatico. Gli attacchi informatici arrivano spesso e sono molto difficili da fermare, perciò l'organizzazione deve mettere in atto misure di sicurezza che funzionino e che seguano standard noti.
Mi sembra chiaro che l'organizzazione deve saper individuare il rischio informatico e deve saper misurare il rischio informatico.
Non è solo una questione tecnica, è il modo per rendere più forti i sistemi di difesa, per ridurre le vulnerabilità e per garantire la continuità operativa.
In un mondo sempre più connesso, la sicurezza informatica è diventata una priorità per tutte le organizzazioni.

Capitolo 1 – Sicurezza Informatica e Gestione del Rischio

Cosa si intende per rischio informatico?

Il **rischio informatico** è la possibilità che eventi dannosi accadano e che rovinino sicurezza, integrità, disponibilità o riservatezza dei sistemi informativi e dei dati. Il rischio informatico nasce da minacce esterne, per esempio attacchi hacker, e da fattori interni, come errori umani, vulnerabilità del software o guasti infrastrutturali.
Anche una azione apparentemente innocua, come aprire una email di phishing, può diventare un problema serio. In quel caso il rischio informatico causa danni economici e danneggia immagine della organizzazione.

Minacce principali e vulnerabilità

Le minacce informatiche sono in aumento e le aziende di tutti i settori devono affrontare una sfida costante. Di seguito elenchiamo i principali tipi di minacce informatiche e le vulnerabilità:

1. **Malware e Ransomware**

Il **malware** è un nome generico per qualsiasi programma dannoso che si infiltra nei sistemi, danneggia i file o interrompe il funzionamento dei processi. Il malware più pericoloso è il ransomware. Il ransomware blocca o cripta i dati aziendali e li rende inaccessibili finché non si paga il riscatto. Nel mio lavoro ho visto come un attacco di ransomware possa paralizzare un'intera azienda in pochi minuti. Un attacco di ransomware chiude l'accesso a documenti e a informazioni cruciali. Il ransomware può fermare le operazioni e mettere a rischio la continuità dell'attività.
Secondo la mia esperienza, oltre alla richiesta di riscatto, un attacco ransomware porta a perdere la fiducia dei clienti dell'organizzazione, rovina la reputazione dell'aziendae può portare a sanzioni legali.

2. **Phishing e Social Engineering**

Gli attacchi di **phishing** sono tra le truffe informatiche più diffuse. Gli attacchi di phishing tendono a far rivelare all'utente informazioni sensibili come password, numeri di carte di credito o dati bancari.
Gli attacchi di phishing arrivano spesso sotto forma di email che sembrano provenire da fonti affidabili: una banca, un fornitore di servizi o un collega. Gli attacchi di phishing invitano l'utente a cliccare su un link pericoloso o a scaricare un allegato con malware. Gli attacchi di phishing permettono così all'hacker di rubare credenziali di accesso o dati finanziari. Io ho visto questi messaggi più volte nella mia casella, e mi ha fatto capire quanto sia facile cadere nella trappola.
Il **social engineering**, è una forma di phishing che sfrutta la psicologia delle persone per ingannarle e accedere ai sistemi aziendali senza permesso. Gli hacker cercano informazioni di contatto o dettagli su una persona o su un'organizzazione.

3. **Attacchi DDoS (Distributed Denial of Service)**

Gli attacchi **DDoS** tendono a sovraccaricare i sistemi aziendali con una quantità enorme di traffico che proviene da una rete di dispositivi compromessi, la **botnet**.
L'obiettivo di un attacco DDoS è rendere i sistemi aziendali, come i siti web o i server, inaccessibili agli utenti legittimi. Quando i sistemi aziendali sono inaccessibili, gli utenti non riescono a usare i servizi e si verificano disservizi che possono durare ore o anche giorni.

Nella mia esperienza, un attacco DDoS non è solo un blocco del servizio. Un attacco DDoS può far scendere le vendite, rovinare la reputazione dell'azienda e, a volte, far perdere la fiducia dei clienti al brand.
È un problema serio. Le aziende che utilizzano piattaforme online per le loro attività quotidiane sono più esposte al rischio di un attacco DDoS.

4. **Vulnerabilità Software e Configurazioni Errate**

Una delle cause più comuni di attacchi informatici è la **vulnerabilità del software** e la configurazione errata dei sistemi aziendali. I programmi non aggiornati, i bug e le falle di sicurezza non risolte possono essere usati facilmente dagli hacker per rubare dati sensibili o per rovinare l'integrità dei sistemi.
Allo stesso modo, una configurazione errata dei sistemi, per esempio l'assenza di protezioni adeguate o l'uso di password deboli, apre la porta agli attacchi.
La mancata gestione dei rischi legati a vulnerabilità del software e a configurazioni errate può compromettere seriamente la sicurezza dell'intera infrastruttura aziendale.

5. **Minacce Interne**

Non tutte le minacce arrivano dall'esterno. Le **minacce interne** rappresentano un rischio significativo.
Le minacce interne possono arrivare da dipendenti, da collaboratori o da partner dell'azienda. Le minacce interne possono essere accidentali, per esempio quando un impiegato apre per sbaglio un'email infetta. Le minacce interne possono anche essere intenzionali, quando una persona con cattive intenzioni prende dati sensibili per usarli o venderli a concorrenti. Le minacce interne sono spesso difficili da scoprire, perché chi le crea ha già le chiavi dei sistemi aziendali e può muoversi senza destare sospetti. Quando i sistemi aziendali vengono compromessi, l'organizzazione si espone a rischi gravi.

Impatto economico e operativo

Quando avviene un attacco informatico, le conseguenze vanno ben oltre la perdita di dati. Un attacco informatico può colpire duramente le risorse economiche, la reputazione e la capacità operativa di un'organizzazione.

In elenco i principali effetti:

1. **Perdite Economiche Dirette e Indirette**

Quando gli attacchi informatici, come il **ransomware**, colpiscono un'azienda, le perdite finanziarie dirette sono spesso molto alte. Il pagamento del riscatto e le spese per recuperare i dati possono arrivare a milioni di euro e rovinare i bilanci aziendali.
Inoltre, l'interruzione dei servizi fa abbassare i ricavi dato che l'azienda non riesce a lavorare o accedere alle risorse essenziali. Se gli attacchi informatici includono informazioni sensibili, l'impatto diventa ancora più grave, perché l'azienda deve affrontare azioni legali per gestire le violazioni.

2. **Danni alla reputazione**

Un altro aspetto fondamentale degli attacchi informatici è il danno alla **reputazione** dell'organizzazione.
Quando gli hacker rubano i dati, la fiducia dei clienti e anche la fiducia dei partner può andare persa. Le aziende che non proteggono bene le informazioni sensibili rischiano di perdere i clienti e di conseguenza ricevere un grave danno economico.

Spesso non riusciamo a recuperare la fiducia in poco tempo. Un attacco informatico rovina l'immagine di un'organizzazione al pubblico. L'immagine dell'organizzazione può poi influenzare le trattative commerciali future.

3. **Implicazioni legali e regolatorie**

Le **implicazioni legali** degli attacchi informatici colpiscono le organizzazioni. Anche se le organizzazioni credono di essere al sicuro, se non mettono in atto misure di sicurezza informatica adeguate, le autorità di regolamentazione possono infliggere sanzioni importanti. Il **GDPR** (Regolamento Generale sulla Protezione dei Dati) è un esempio chiaro. Il GDPR prevede multe che possono arrivare fino al 4% del fatturato annuale di un'organizzazione, se l'organizzazione non rispetta gli obblighi di protezione dei dati sensibili.

4. **Interruzione delle attività aziendali**

Gli attacchi informatici bloccano le attività di tutti i giorni. Quando gli hacker violano i sistemi, non si può più accedere ai dati né le applicazioni importanti, e l'operatività resta bloccata. A volte l'interruzione dura giorni, a volte settimane, e questo impedisce di servire i clienti.
Se il supporto clienti o la gestione degli ordini si blocca, i clienti perdono fiducia nel marchio. Con il tempo, la perdita di fiducia fa calare le vendite.

5. **Costi di ripristino e rafforzamento della sicurezza**

Dopo un attacco informatico bisogna affrontare un lungo percorso di recupero. Le organizzazioni devono spendere molte risorse per fare indagini forensi e scoprire la causa e l'origine dell'attacco. Quando le organizzazioni capiscono la natura della violazione, esse devono mettere in atto nuove misure di protezione per evitare altri attacchi.
Le nuove misure di protezione possono richiedere investimenti importanti in software di sicurezza, in hardware e in consulenze specializzate.
Inoltre, le organizzazioni devono garantire una formazione continua del personale. La formazione del personale aiuta i dipendenti a riconoscere le minacce e a usare pratiche sicure. Chi mette in atto un piano per rispondere agli incidenti e per gestire la sicurezza deve agire in modo veloce e deciso. Il piano deve essere veloce e deciso per evitare che il danno diventi continuo e irreversibile.

Capitolo 2 - Calcolo del Fattore di Rischio

Importanza del calcolo del rischio

Il calcolo del **fattore di rischio** è fondamentale per gestire la sicurezza e per tenere sotto controllo le minacce. Il calcolo del fattore di rischio si basa su due elementi: la probabilità che una minaccia si verifichi e l'impatto che la minaccia può avere se si realizza.
Il calcolo del fattore di rischio produce un valore numerico che indica quali sono i rischi più importanti. Io uso il valore numerico del fattore di rischio per capire quali rischi meritano più attenzione. Con il valore numerico del fattore di rischio è possibile decidere dove destinare le risorse di sicurezza. Le risorse di sicurezza vanno assegnate prima alle minacce più gravi e più urgenti.

1. Formule e metodologie di analisi

Formula del Rischio

Il calcolo del rischio può essere eseguito utilizzando la seguente formula:

$$R = P \times I \times V$$

Dove:

- R è il rischio informatico.
- P è la probabilità che una minaccia si verifichi.
- I è l'impatto di tale minaccia.
- V è la vulnerabilità dei sistemi.

2. Metodologie di Calcolo del Rischio

Metodologia OCTAVE

OCTAVE (Operationally Critical Threat, Asset, and Vulnerability Evaluation) è una metodologia di gestione del rischio che si concentra sull'identificazione e sulla gestione dei rischi relativi agli asset critici, alle minacce e alle vulnerabilità di un'organizzazione. Questo approccio qualitativo consente di valutare in modo sistematico il rischio, considerando gli aspetti operativi e la sicurezza informatica.

Le fasi principali di OCTAVE sono:

1. **Identificazione degli asset critici**: Determinare quali sono i beni aziendali più importanti da proteggere.
2. **Identificazione delle minacce**: Elencare le minacce che potrebbero compromettere gli asset identificati.
3. **Analisi delle vulnerabilità:** Rilevare le debolezze presenti nei sistemi che potrebbero essere sfruttate dalle minacce.
4. **Valutazione del rischio:** Combinare la probabilità e l'impatto delle minacce e vulnerabilità per determinare il livello di rischio.

Metodologia FAIR

FAIR (Factor Analysis of Information Risk) è un framework quantitativo che consente di valutare il rischio finanziario, piuttosto che solo il rischio operativo. Questa metodologia si basa su calcoli statistici per determinare la probabilità e l'impatto, in particolare in termini economici, di un evento dannoso.

Le fasi di FAIR comprendono:

1. **Identificazione del rischio:** Determinare la natura della minaccia e della vulnerabilità.
2. **Quantificazione del rischio:** Stimare la probabilità dell'evento dannoso e la perdita economica potenziale.
3. **Calcolo della perdita attesa:** Moltiplicare la probabilità dell'evento per la perdita economica media per determinare il rischio finanziario complessivo.

ISO 31000:2018

ISO 31000 è una norma internazionale. La norma ISO 31000 dà indicazioni generali su come gestire il rischio in ogni contesto. Quando si tratta di informatica, la gestione del rischio comprende l'identificazione del rischio, la valutazione del rischio e la risposta al rischio.

Le fasi di gestione del rischio secondo ISO 31000 sono:

a. **Contesto:** Definizione del contesto in cui si opera.
b. **Identificazione:** Identificazione delle minacce e vulnerabilità.
c. **Valutazione:** Calcolo della probabilità e dell'impatto.
d. **Trattamento del rischio:** Definizione di misure di mitigazione.
e. **Monitoraggio:** Controllo continuo delle vulnerabilità.

3. Applicazione Pratica del Calcolo del Rischio

Per fare un'analisi di rischio pratica serve usare metodologie e strumenti tecnici avanzati. In questa sezione mostriamo il processo passo dopo passo. Applichiamo il processo a casi reali. Dimostriamo concretamente come si fa una valutazione completa del rischio.

Fase 1: Identificazione degli Asset

Il primo passo è capire quali sono gli **asset** critici della organizzazione.
Gli asset critici includono dati sensibili, infrastrutture tecnologiche, applicazioni aziendali e risorse umane. Se una società gestisce dati finanziari, allora questa società deve concentrare l'analisi sul rischio di violazione della privacy dei dati finanziari.

Fase 2: Identificazione delle Minacce

Le minacce rappresentano eventi esterni o interni che potrebbero compromettere gli asset aziendali.

Le minacce comuni includono:

- **Attacchi informatici** (phishing, ransomware, hacking)
- **Errori umani** (incidenti causati da disattenzione o negligenza)
- **Malfunzionamenti tecnici** (guasti hardware o software)

Fase 3: Valutazione della Probabilità e dell'Impatto

Dopo aver identificato le minacce, bisogna capire quanto è probabile che le minacce si verifichino e che danni le minacce potrebbero causare. In questa fase si trova la metodologia **FAIR**.
La metodologia FAIR permette di stimare in modo numerico la probabilità delle minacce e l'impatto delle minacce.

- **Probabilità**: Quanto è probabile che una minaccia si realizzi? Ad esempio, un attacco ransomware potrebbe essere considerato ad alta probabilità se i sistemi non sono aggiornati.
- **Impatto**: Quanto grave sarebbe l'evento? La perdita di dati sensibili, per esempio, potrebbe comportare danni legali e reputazionali gravi.

Fase 4: Applicazione nel caso reale

Dopo aver identificato gli asset, le minacce, e aver valutato la probabilità e l'impatto, è possibile applicare la metodologia di calcolo del rischio a dei casi di aziende reali.

Primo caso azienda di telecomunicazioni - Attacco DDoS (Distributed Denial of Service)

Prendiamo come esempio un'azienda di telecomunicazioni, potrebbe dunque essere vulnerabile agli attacchi **DDoS** (Denial of Service), che mirano a sovraccaricare i server dell'azienda con un grande volume di traffico internet, impedendo agli utenti legittimi di accedere ai servizi.

Applicazione della Formula del Rischio

- **Probabilità (P)**: Gli attacchi DDoS sono molto comuni nel settore delle telecomunicazioni. L'esperienza e i dati storici suggeriscono che l'azienda ha una probabilità del 70-80% di essere attaccata ogni anno. Pertanto, **P = 0.8**.
- **Impatto (I)**: L'impatto di un attacco DDoS sull'azienda include l'interruzione dei servizi, la perdita temporanea di clienti, il danno alla reputazione e l'eventuale perdita di ricavi. Poiché la disponibilità dei servizi è fondamentale per l'azienda, l'impatto potrebbe essere significativo, ma non catastrofico se l'azienda è pronta con misure di backup. Pertanto, **I = 0.7**.
- **Vulnerabilità (V)**: La vulnerabilità dell'azienda dipende dalla capacità dei suoi sistemi di resistere a un attacco DDoS. Se l'azienda non ha implementato misure di difesa adeguate, la vulnerabilità potrebbe essere alta. Se, tuttavia, sono in atto misure di difesa come l'uso di soluzioni anti-DDoS, la vulnerabilità potrebbe essere bassa. Supponiamo che l'azienda abbia una vulnerabilità media, **V = 0.6**.

$$R = P \times I \times V = 0.8 \times 0.7 \times 0.6 = 0.336$$

Il rischio calcolato è **0.336**, che indica un rischio **moderato-alto**. Questo significa che l'azienda deve prendere provvedimenti per ridurre il rischio, ad esempio aumentando la capacità di difesa contro gli attacchi DDoS e potenziando la resilienza dei suoi servizi.

Misure di Mitigazione

- **Mitigazione della probabilità (P)**: Migliorare i sistemi di rilevamento degli attacchi in tempo reale e diversificare le risorse di rete.
- **Mitigazione dell'impatto (I)**: Investire in **backup ridondanti** e infrastrutture scalabili per garantire che i servizi possano restare online anche durante gli attacchi.

- **Mitigazione della vulnerabilità (V)**: Aumentare la protezione dei server con tecnologie avanzate di **anti-DDoS**.

La probabilità di attacchi DDoS è alta per un'azienda di telecomunicazioni, e l'impatto di tali attacchi potrebbe essere significativo. Utilizzando **FAIR**, possiamo calcolare con maggiore precisione la probabilità di incorrere in un attacco DDoS e l'entità della perdita economica in caso di disservizio.

OCTAVE aiuta a valutare l'importanza degli asset critici (come le reti e i dati degli utenti) e ad analizzare le vulnerabilità interne ed esterne, come l'accesso non autorizzato o le interruzioni di servizio.

Secondo caso settore bancario - Attacco Ransomware

Prendiamo come esempio una banca, potrebbe essere colpita da un attacco **ransomware**, dove i criminali informatici bloccano l'accesso ai dati sensibili della banca e chiedono un riscatto per il rilascio.

Applicazione della Formula del Rischio

- **Probabilità (P)**: Gli attacchi ransomware sono comuni nel settore bancario e la probabilità che la banca sia attaccata è abbastanza alta. Poiché l'industria bancaria è un obiettivo primario per i criminali informatici, supponiamo che la probabilità di attacco sia **P = 0.7**.
- **Impatto (I)**: L'impatto di un attacco ransomware per una banca è elevato. La perdita di dati sensibili dei clienti, la sospensione dei servizi bancari, il danno economico e la possibile multa per violazione della sicurezza sono tutte conseguenze gravi. Pertanto, l'impatto sarà valutato come **I = 0.9**.
- **Vulnerabilità (V)**: La banca ha probabilmente una vulnerabilità relativamente bassa, poiché utilizza misure avanzate di protezione come crittografia dei dati e soluzioni antivirus. Tuttavia, la vulnerabilità potrebbe essere aumentata dalla possibilità di attacchi tramite **phishing** o altri vettori non tecnici. Pertanto, la vulnerabilità potrebbe essere **V = 0.7**.

$$R = P \times I \times V = 0.7 \times 0.9 \times 0.7 = 0.441$$

Il rischio calcolato è **0.441**, che rappresenta un rischio **alto**. Questo significa che la banca deve investire maggiormente nella protezione contro gli attacchi ransomware.

- **Mitigazione della probabilità (P)**: Sensibilizzare i dipendenti sui rischi di phishing e implementare filtri avanzati per le email.
- **Mitigazione dell'impatto (I)**: Implementare sistemi di backup regolari e disaster recovery per recuperare rapidamente i dati critici.
- **Mitigazione della vulnerabilità (V)**: Aumentare la protezione contro l'accesso non autorizzato e migliorare la formazione dei dipendenti sulla sicurezza informatica.

Applicazione delle Metodologie

Con **FAIR** nel caso della banca, si potrebbe calcolare la probabilità di attacchi ransomware, analizzando quante volte questo tipo di attacco si verifica nel settore bancario e quale potrebbe essere l'impatto economico (inclusi i costi per il recupero dei dati e le perdite reputazionali).

Utilizzando **OCTAVE**, è possibile determinare le minacce più rilevanti, come attacchi ransomware e frodi bancarie, e definire le misure di protezione necessarie per evitare che queste minacce compromettano la sicurezza dei dati bancari e la continuità dei servizi.

Conclusioni

La guida vuole dare una comprensione chiara del calcolo del **fattore di rischio**. Essa esamina il quadro normativo che riguarda il calcolo del fattore di rischio e propone metodologie pratiche e applicabili per il calcolo di quest'ultimo.
Il metodo che usiamo combina dati numerici e dati di tipo qualitativo. Così il metodo dà una valutazione precisa e flessibile. Mentre è stato sviluppato, ho voluto che fosse chiaro e facile da usare. Ho cercato di bilanciare l'accuratezza tecnica con la semplicità d'uso per dare un aiuto valido. Ho creato una pagina web per scaricare il documento. Ho costruito la pagina web con HTML e CSS.
A mio avviso, in futuro il modello potrà evolversi. Il modello potrebbe utilizzare strumenti automatici per l'analisi dei dati e potrà avere una piattaforma interattiva.
La **sicurezza** non è un traguardo finale. La sicurezza è un processo continuo e in evoluzione. Il processo di sicurezza cambia quando le minacce cambiano. Io credo che la sicurezza debba sempre stare al passo con le nuove minacce.